

Annex A Control Implementation Guide

Purpose

Folder 06 connects the Statement of Applicability to practical implementation and objective evidence for the 93 ISO/IEC 27001:2022 Annex A controls.

A.5 Organizational Controls

Focus on governance, policies, roles, asset management, access governance, supplier security, incident management, continuity, compliance and documented operating procedures.

A.6 People Controls

Focus on screening, employment terms, awareness and training, disciplinary arrangements, termination/change, confidentiality, remote working and event reporting.

A.7 Physical Controls

Focus on physical perimeters, entry, secure areas, monitoring, environmental threats, equipment protection, off-premises assets, media and secure disposal.

A.8 Technological Controls

Focus on endpoints, privileged access, authentication, vulnerabilities, malware, backups, logging, monitoring, network security, cryptography, secure development and change management.

Implementation method

For each control: define the requirement → assign an owner → implement the process/technical measure → retain objective evidence → review operation → record findings and corrective actions.

Auditor perspective

The auditor should be able to trace SoA → control/process → responsible owner → operating evidence. A policy demonstrates intent; operational records demonstrate implementation and operation.

Portfolio limitation

This is a simulated portfolio project. It is not an actual certification claim. Real audit evidence must be genuine, current, controlled and attributable to the organization.